

Penetration Testing Report

IDOR (Insecure Direct Object Reference) — Employee Profile Access

StaffHub Employee Portal — IDOR Analysis

Project	StaffHub Employee Portal (IDOR Analysis)
Target	localhost, port 8080
Tester	Surakshya Chhetri
Date of Assessment	12 August 2026
Vulnerability Class	Broken Access Control — Insecure Direct Object Reference (IDOR)
Risk Rating	High

1. Overview

This document presents the findings and methodology for a penetration test focused on Insecure Direct Object Reference (IDOR) vulnerabilities within the StaffHub Employee Portal. The purpose of the assessment was to examine the employee profile functionality and determine whether user-supplied input in the URL was adequately validated and protected against unauthorized access.

The assessment specifically evaluated how the application handled profile identifiers (IDs), whether proper access control checks were enforced, and whether manipulating request parameters could expose pages or resources that should otherwise remain restricted. During testing, a significant vulnerability was identified within the employee profile module.

While reviewing the profile pages, the 'id' parameter in the URL was modified to values that were not listed or linked within the standard employee directory. This manipulation made it possible to access hidden or restricted profiles including the profile belonging to the CEO which contained a flag confirming successful exploitation. This report documents the full set of results, evidence, and recommendations arising from the IDOR testing conducted against the web application within a controlled, secure lab environment.

2. Vulnerability Summary

- Vulnerability: IDOR – Profile Access Bypass
- Severity / Risk Rating: High
- Impact: Unauthorized access to employee data and other sensitive information
- OWASP Category: A01:2021 – Broken Access Control
- Affected Component: Employee profile endpoint (/profile?id=)

3. Scope of Testing

- Employee directory and profile functionality
- URL parameter handling (specifically the 'id' parameter)

- Server-side access control checks
- Discovery of hidden or unlisted employee profiles
- Flag retrieval as proof of successful exploitation

4. Objectives

- Determine whether profile-related inputs passed through the URL were vulnerable to manipulation.
- Assess whether the IDOR vulnerability allowed unauthorized users to access restricted data.
- Attempt to bypass access controls in order to view hidden or protected employee records.
- Evaluate whether sensitive employee information could be exposed as a result.
- Provide an overall assessment of the security posture of the profile-handling mechanism.

5. Methodology

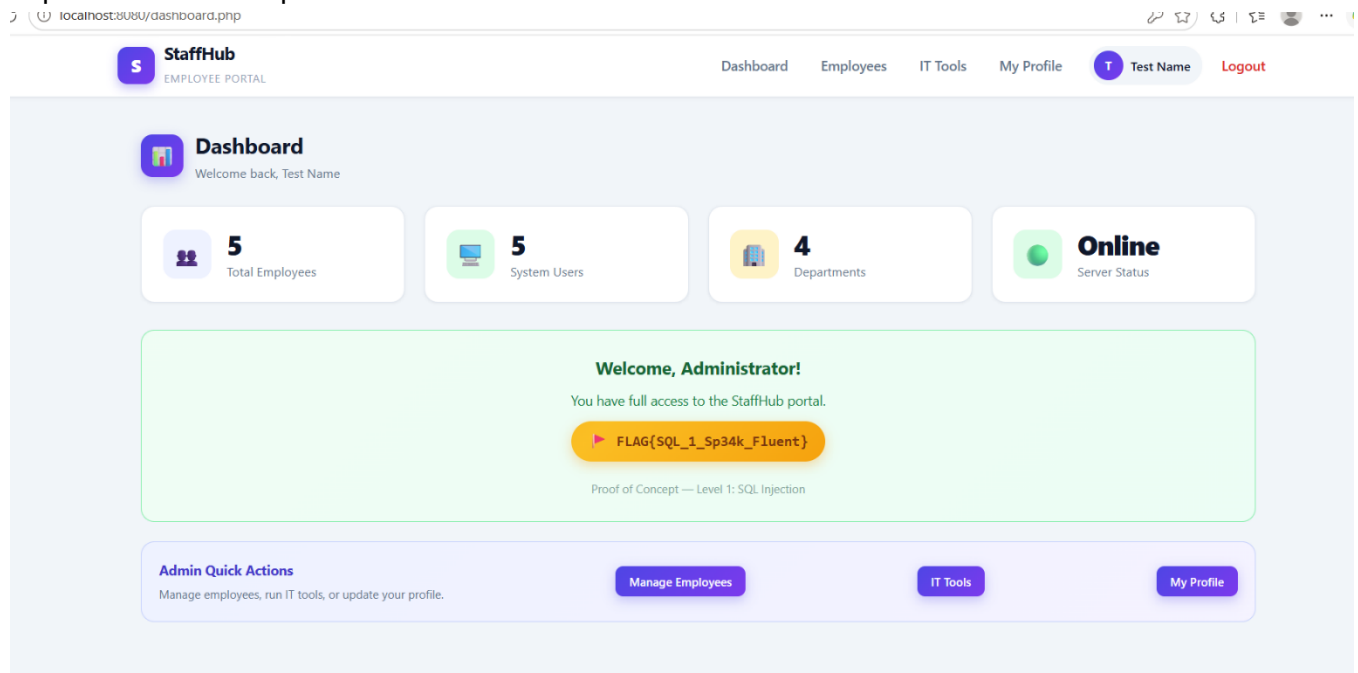
- Testing was conducted within a secure, isolated lab environment to prevent any unintended impact.
- The employee directory was reviewed, and the structure of profile URLs was observed and documented.
- The 'id' parameter was systematically modified to values that did not appear within the visible employee directory.
- Each request was checked to confirm whether the application enforced proper authorization before returning data.
- Hidden employee profiles were discovered through this process, ultimately leading to retrieval of the flag.

6. Testing Approach

All testing was carried out in a controlled and non-destructive manner, consistent with authorized penetration-testing practice.

The assessment began by locating the employee directory link, which was initially identified with the help of an earlier finding (Flag 1). Once the general structure of the profile URLs was understood, the following endpoint was examined:

http://localhost:8080/profile?id=1



This request was used to determine whether the value supplied in the 'id' parameter could be modified or manipulated to access records outside the intended scope. As a result of this test, the application returned sensitive employee information, confirming that the underlying data was exposed without adequate authorization checks.

7. Exploitation Process

Step 1 — Access the Employee Directory

The employee directory was first accessed using the reference obtained from Flag 1 (identified during an earlier SQL injection test):

http://localhost:8080/employee

localhost:8080/employees.php

StaffHub
EMPLOYEE PORTAL

Dashboard Employees IT Tools My Profile Test Name Logout

Employee Directory

All employees registered in the system

EMPLOYEE	DEPARTMENT	POSITION	ACTION
 John Doe ID: 1	IT	Software Engineer	View
 Jane Smith ID: 2	HR	HR Manager	View
 Mike Wilson ID: 3	Finance	Accountant	View
 Sarah Lee ID: 4	IT	System Administrator	View
 Robert Chen ID: 5	Management	Chief Executive Officer	View

Step 2 — Identify the URL Pattern

The structure of the URL was then reviewed to determine whether the 'id' parameter relied on sequential, predictable identifiers. It was confirmed that the application used sequential employee IDs, which is a classic indicator of an IDOR vulnerability, since such identifiers are easily guessed or enumerated by an attacker.

localhost:8080/employees.php

StaffHub
EMPLOYEE PORTAL

Employee Directory

All employees registered in the system

Step 3 — Manipulate the Parameter

The 'id' parameter was then deliberately altered, and the modified URL was submitted as a request. This step was used to test whether the application performed any missing or insufficient authorization checks before returning profile data.



Employee Profile

Employee ID: 2



HR

Jane Smith

HR Manager

Employee ID	2
Department	HR
Email	jane.smith@techcorp.com
Phone	555-0102
Salary	\$82,000.00

NOTES

Oversees recruitment and employee relations.



Employee Profile

Employee ID: 2



HR

Jane Smith

HR Manager

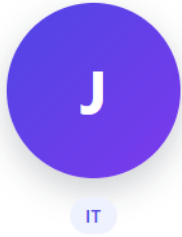
Employee ID	2
Department	HR
Email	jane.smith@techcorp.com
Phone	555-0102
Salary	\$82,000.00

NOTES

Oversees recruitment and employee relations.

Step 4 — Enumerate Hidden Records

By sequentially trying different ID values, it became possible to determine the approximate total number of employee records, including a number of profiles that were hidden from the standard, publicly browsable directory.



John Doe

Software Engineer

Employee ID	1
Department	IT
Email	john.doe@techcorp.com
Phone	555-0101
Salary	\$75,000.00

NOTES

Joined Jan 2020. Leads frontend team.

Step 5 — Retrieve the CEO's Profile and Flag

Based on the pattern observed, hidden or privileged accounts (such as the CEO's profile) were often associated with an ID value at either the low or high end of the numeric range. Testing these boundary values successfully returned the CEO's profile, which contained the flag confirming the vulnerability.



Robert Chen

Chief Executive Officer

Employee ID	5
Department	Management
Email	robert.chen@techcorp.com
Phone	555-0100
Salary	\$150,000.00

NOTES

CEO and founder. Flag backup located at /var/www/flags/flag2.txt

► FLAG CAPTURED

FLAG{All_Y0ur_B4s3_Are_B3l0ng_T0_U5}

8. Evidence

Screenshots captured during testing demonstrate the vulnerability at each stage: the employee directory listing, the sequential ID pattern in the profile URL, the manipulated request, and the successful retrieval of the restricted CEO profile containing the flag. These screenshots are referenced as supporting evidence for this report and should be attached as appendices.

9. Flag

The retrieved flag confirms the presence of the vulnerability and demonstrates successful, unauthorized access to a restricted resource. In a real-world deployment, this class of vulnerability could expose highly sensitive information, including confidential company data or financial records, rather than a benign test flag.

10. Impact

- Attackers can view sensitive employee information such as email addresses, phone numbers, salary details, and other personal data.
- Unauthorized exposure of personal information constitutes a serious privacy violation and may carry legal or regulatory consequences.
- Even ordinary, authenticated employees could access one another's private profiles without permission.
- Attackers can potentially harvest all employee records simply by iterating through sequential IDs.
- Such a breach undermines trust between employees, management, and other stakeholders, and could damage the organization's reputation.

11. Risk Rating Justification

This vulnerability is rated High because it requires minimal technical skill to exploit, can be automated at scale (e.g., through simple ID enumeration scripts), and exposes personally identifiable information (PII) as well as potentially sensitive executive-level data without any authentication bypass or complex attack chain.

12. Remediation Recommendations

- Implement strict, server-side access control checks on every profile request, verifying that the requesting user is authorized to view the specific record.
- Never rely on client-side or URL-based restrictions alone; all authorization decisions must be enforced on the server.
- Replace predictable, sequential identifiers with indirect references such as UUIDs or randomly generated tokens that cannot be easily guessed or enumerated.
- Enforce role-based access control (RBAC) so that users can only view data appropriate to their role and permission level.
- Implement logging and monitoring of profile access requests to detect unusual or unauthorized access patterns in real time.
- Conduct regular access-control testing as part of the software development lifecycle to catch similar issues before deployment.

13. Conclusion

The IDOR vulnerability discovered within the StaffHub Employee Portal represents a critical security flaw. It allowed simple, unauthenticated access to sensitive employee information through nothing more than a straightforward change in the URL's ID parameter. Unauthorized access to the CEO's profile in particular illustrates how this type of flaw could expose highly confidential company information in a production environment, potentially leading to a significant real-world data breach. Prompt remediation, following the recommendations outlined above, is strongly advised to eliminate this risk.

14. Closing Note

Beyond the technical findings, this assessment also serves as a reminder of the broader discipline required in security work: setting clear testing goals, maintaining a strong and methodical work ethic, and continuously learning from each engagement. Staying focused and adaptable — especially when encountering obstacles during testing — along with good time management, clear reporting, and a supportive team, all contribute to consistent, high-quality results. Ultimately, effective penetration testing, like most professional growth, is the product of persistence, adaptability, and an ongoing commitment to self-improvement.